

CRM Manager Access Audit Report

Audit date: 2026-07-29

Scope: Manager access only

Modules reviewed: Dashboard, Notifications, Users / Executives, Leads, Prospects, Quotations, Customers, Reports, Profile, Settings, Help

Mode: Read-only code audit. No application code or functionality was changed.

Executive Summary

The Manager role has a solid foundation in several places: dashboard metrics are mostly scoped to the Manager plus active direct-report Executives, prospect and quotation visibility use ownership checks, user listing shows only direct-report Executives, and Settings/Billing/Audit/Announcement authoring are not exposed to Managers.

The highest risk is inconsistent team-level authorization. Some list queries correctly apply `managerId`, but several direct-ID mutation paths and shared assignment validators only check organization and role. That creates a gap where a Manager can potentially view or manage other Managers' Executives by crafted API calls, assign leads outside their own team, and expose organization-wide Executive names through shared dropdown endpoints.

Priority should be to centralize a strict Manager scope helper and reuse it everywhere: list, detail, create, update, assign, status transition, export, and dashboard/report queries. The product rule should be: Manager scope equals `self OR users where managerId = manager.id`; anything outside that returns 403, not an empty list or UI-only restriction.

Highest Priority Findings

Severity	Area	Finding	Correct Direction
Critical	Users / Executives	Manager list is scoped to direct reports, but `getUserById`, update, delete, disable, and enable rely on role-only `canManageUser(MANAGER, EXECUTIVE)`. A Manager with an Executive ID can manage any Executive in the organization.	Add a backend `assertManagerCanManageExecutive(managerId, targetUser)` check to every user detail and mutation path.
Critical	Leads / Prospects	`validateLeadAssignee` allows Manager assignment to any active Executive in the organization. `getAssignableUsers` also returns all org Executives, not only direct reports. Prospects reuse this validator.	For Managers, allow only self or `assignee.managerId === manager.id`; dropdown endpoint must return only self plus direct reports.
High	Lead Data Isolation	Lead `productInterestId` can connect to an Item by ID without validating the Item belongs to the same organization.	Validate item IDs through org-scoped item repository before connect/update/import.
High	Reports	Reports are mostly scoped, but the Executive filter UI uses the lead assignable-users endpoint, which currently leaks all org Executive names to Managers.	Use a dedicated report-assignee endpoint or fix assignable-users to Manager direct scope.
High	Profile / Password	UI hides password change for Managers, but `/auth/change-password` allows any authenticated user. If Manager password changes are restricted by rule, the backend does not enforce it.	Enforce the password policy server-side, or update UI/product rule so self-service password change is explicitly allowed.
Medium	Dashboard	`customersConverted` for Manager is counted only from team leads assigned by the Manager, not all Manager-owned plus team-owned won customers. This can undercount Manager direct wins and team customers created through other valid flows.	Align the KPI with the Manager data contract: self plus direct team, with a separate "assigned by me" metric if needed.
Medium	UI Actions	Manager sees Lead and Quotation delete actions in tables, but backend role permissions do not grant delete.	Hide actions using the same permission matrix as backend; keep backend denial as final guard.
Medium	Settings	User requested Manager Settings audit, but Settings route/sidebar are restricted to Super Admin and Admin only.	Confirm intended product rule. If Managers need settings, create a restricted Manager Settings surface; otherwise document "not available to Manager."

Role And Access Model Observed

- Manager sidebar includes Dashboard, Notifications, Users, Items, Leads, Prospects, Quotations, Customers, and Reports.
- Manager is not given Billing, Organizations, Announcements authoring, Audit Log, or Settings in route/sidebar config.
- Backend role permissions grant Managers create/read/update for Users, Items, Leads, Prospects, Quotations, and Reports, plus user disable/enable/delete permissions.
- Manager data scoping is implemented differently per module. Dashboard, prospect list, quotation list, and reports often use `self OR direct reports`; user detail/mutation and lead assignment do not consistently enforce the direct-report rule.

- Items are visible/manageable for Managers even though Items were not included in the requested Manager module list. This should be confirmed as intentional.

Module-Wise Audit Report

1. Dashboard

Category	Audit Detail
Bugs/issues found	Manager dashboard correctly defines direct leads as `assignedToId = managerId`, team assigned leads as Executive leads with `assignedById = managerId`, open leads as `NEW`, `ATTEMPTED\_CONTACT`, and `CONTACTED`, and Executive performance from active direct reports. Main issue: `customersConverted` uses only team leads assigned by Manager, so Manager direct customers and valid team customers not assigned by Manager can be undercounted. Follow-up due count is based on follow-up activity metadata, which can drift from the current prospect follow-up fields.
Edge cases to test	Manager with no Executives; Manager with direct leads only; Manager with team leads assigned by Admin; Executive moved from Manager A to Manager B; suspended organization login; disabled Executive with historical leads; timezone boundary for today's follow-ups.
Severity	Medium
Affected functionality	KPI accuracy, conversion percentage, follow-up widgets, executive performance chart.
Possible root cause	Dashboard uses several slightly different scopes: direct lead scope, team assigned-by-manager scope, manager team scope, and prospect scope. KPI definitions are not all tied to one Manager ownership contract.
Best-practice solution	Define explicit metric contracts: "direct to Manager", "assigned by Manager to team", and "Manager total scope". Use one shared helper for Manager-owned records and only specialize when the label clearly says "assigned by me."
Performance improvements	Keep current parallel query pattern, but consider a small materialized analytics view or cached aggregate for large tenants. Add DB indexes on `Lead(organizationId, assignedToId, deletedAt, status)`, `Lead(organizationId, assignedById, assignedToId)`, `Prospect(organizationId, assignedToId, stage)`, and `Quotation(organizationId, assignedToId, createdById, status)`.
Testing checklist	Verify direct lead count excludes team leads; verify team assigned count includes only Manager-assigned Executive leads; verify open lead count only uses `NEW`, `ATTEMPTED\_CONTACT`, `CONTACTED`; verify chart excludes other Managers' Executives; verify empty states render when no data; verify dark/light cards and charts remain readable on mobile.

2. Notifications

Category	Audit Detail
Bugs/issues found	Notifications appear user-scoped, and announcements are read through the feed. However, any notification deep-link to `/settings` will fail for Managers because Settings is not Manager-accessible. Mark-all-read appears capped, so Managers with many unread notifications may need repeated actions.
Edge cases to test	Manager receives org-wide announcement; Manager receives role-targeted announcement; Manager in suspended organization; 201+ unread notifications; deleted target entity; notification for a lead reassigned away from Manager's team.
Severity	Medium
Affected functionality	Notification bell count, feed navigation, announcement visibility, stale entity links.
Possible root cause	Notifications are generic while role route availability differs. Bulk read logic is optimized for a limited batch.
Best-practice solution	Store notification target role/permission metadata and resolve links based on current user access. Bulk update all unread rows for the current user or page through explicit pagination.
Performance improvements	Index `Notification(userId, readAt, createdAt)` and `AnnouncementReceipt(userId, announcementId)`. Avoid refetching the full feed after single read actions if the cache can be patched.
Testing checklist	Validate only Manager-visible announcements appear; verify deleted/reassigned entity notification handles 403/404 gracefully; verify unread badge after bulk read; verify mobile feed; verify dark/light announcement cards.

3. Users / Executives

Category	Audit Detail
Bugs/issues found	Manager user listing is correctly filtered to `role = EXECUTIVE` and `managerId = loggedInUser.id`. Critical issue: direct user detail/mutation paths use role-only permission. A Manager can potentially view, update, disable, enable, delete, or change manager assignment for any same-organization Executive if they know the ID. Manager update can also set `managerId` to another same-org Manager because the validation only checks organization membership. User stats are calculated from the currently loaded page, so totals can be wrong under pagination.
Edge cases to test	Manager A requests Executive under Manager B by ID; Manager A disables Manager B's Executive; Manager A updates `managerId`; Manager creates Executive at seat limit; Manager enables inactive Executive when seat

limit reached; duplicate email/employee ID; paginated list with more than 10 Executives. |
Severity	Critical
Affected functionality	Team isolation, user management, seat governance, audit trust, dashboard/report downstream accuracy.
Possible root cause	`permissions.canManageUser` only evaluates role hierarchy and does not know team ownership. List scope and mutation scope are separate.
Best-practice solution	Add a backend team authorization guard: for Manager, target user must be an Executive with `managerId === manager.id`. Apply it in `getUserById`, update, delete, disable, enable, password/admin actions, and any bulk endpoints. For Manager updates, force `managerId` to remain the Manager's own ID or disallow manager changes entirely.
Performance improvements	Add indexes on `User(organizationId, role, managerId, status, deletedAt)` and cap `limit`. Move user stats to a backend stats endpoint that counts full result scope instead of current page.
Testing checklist	Verify list shows only direct Executives; verify detail by ID for other-team Executive returns 403; verify Manager cannot create Manager/Admin; verify Manager-created Executive gets `managerId = Manager.id`; verify disable/enable/delete are direct-team only; verify page 2 stats remain correct; verify audit log captures Manager user actions.

4. Leads

Category	Audit Detail
Bugs/issues found	Manager lead list is scoped to self or direct-report Executives. Critical issue: `getAssignableUsers` returns Manager plus all active org Executives, and `validateLeadAssignee` allows assigning to any org Executive. That lets a Manager assign or reassign outside their team and exposes names of other teams. Lead create/update can connect `productInterestId` to an Item without org validation. Manager sees delete actions in lead tables, but backend permissions do not grant Manager delete.
Edge cases to test	Manager assigns lead to another Manager's Executive; Manager creates lead with outside-team assignee; Manager updates lead product to cross-org item ID; converted lead status change; import leads with assignee columns; lead reassigned away then accessed by original Manager; suspended org; empty lead table.
Severity	Critical
Affected functionality	Lead ownership, assignment workflow, product-interest integrity, UI action consistency, data isolation.
Possible root cause	Assignment validator checks role and organization but not direct reporting relationship. UI uses a shared assignable-users endpoint that is not Manager-team scoped. Item connection is not validated through an org-scoped lookup before Prisma connect.
Best-practice solution	For Managers, assignable users should be self plus direct-report Executives only. Assignment validation must enforce the same. Validate product/item IDs against `organizationId` and active status before connect. Hide delete for Managers or grant/delete intentionally with backend and audit support.
Performance improvements	Cap filter `limit`; add indexes on `Lead(organizationId, assignedToId, status, deletedAt)`, `Lead(organizationId, assignedById)`, `Lead(organizationId, productInterestId)`. For imports, validate all referenced users/items in bulk.
Testing checklist	Verify Manager lead assignment dropdown only shows own direct team; verify API rejects other-team Executive IDs; verify direct assigned count; verify "Leads Assigned to Team" only counts Manager-assigned Executive leads; verify open status formula; verify search/filter/pagination; verify loading/empty states; verify dark/light lead table.

5. Prospects

Category	Audit Detail
Bugs/issues found	Prospect list and access guard use ownership, so Managers should see prospects assigned to self or direct team. However, prospect assignee validation delegates to lead assignee validation, so it inherits the "any org Executive" assignment bug. Follow-up assignment can therefore also target outside-team Executives. Prospect activity/follow-up reporting relies on activity metadata, which can drift from current prospect fields.
Edge cases to test	Convert qualified Manager lead to prospect; assign prospect/follow-up to other-team Executive; update terminal `WON` or `LOST` prospect; overdue follow-up at timezone boundary; activity add/edit with invalid date; lead assigned to team but prospect assigned elsewhere.
Severity	High
Affected functionality	Prospect visibility, follow-up ownership, pipeline stage accuracy, reports and dashboard follow-up metrics.
Possible root cause	Shared assignee validation is not team-aware. Follow-up state is split between prospect fields and activity metadata.
Best-practice solution	Reuse strict Manager assignee guard for prospects and follow-ups. Treat current prospect follow-up fields as the source of truth and use activities as history. Ensure terminal prospects remain read-only except for explicit Admin/Super Admin recovery actions.
Performance improvements	Index `Prospect(organizationId, assignedToId, stage, followUpDate)` and `ProspectActivity(prospectId, type, createdAt)`. Avoid loading full activity lists for high-volume follow-up

analytics. |

| Testing checklist | Verify Manager sees own/team prospects only; verify other-team prospect by ID returns 403; verify follow-up assignment only direct team; verify `WON/LOST` read-only behavior; verify pipeline stage filters; verify mobile cards and dark/light stage badges. |

6. Quotations

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Quotation visibility and assignment are better scoped than leads: Managers can assign quotations only to self or direct reports. Status rules prevent Executives from approval/rejection and prevent Managers from approving/rejecting their own quotations. UI still shows status actions even when backend will reject the transition, and the quick status dialog does not collect a rejection reason even though backend requires one for `REJECTED`. Delete is visible to Managers in desktop/mobile quotation tables, but backend permissions do not grant Manager delete. |

| Edge cases to test | Manager approves Executive quotation; Manager attempts to approve own quotation; reject without reason; approved to pending by Manager; quotation assigned to inactive Executive; PDF preview with missing assets; invalid item totals; quotation linked to prospect outside Manager scope. |

| Severity | High |

| Affected functionality | Approval workflow, rejection workflow, UI consistency, PDF preview, audit trail. |

| Possible root cause | Backend status transition rules are richer than frontend action availability. UI role checks use `not Executive` instead of permission-aware checks. |

| Best-practice solution | Create frontend permission helpers mirroring backend quotation transitions. Add rejection reason UI. Hide delete for Managers or explicitly implement Manager delete with backend permissions and audit. Validate linked prospect ownership and items before creating/updating quotations. |

| Performance improvements | Index `Quotation(organizationId, assignedToId, createdById, status, date, deletedAt)`. Cache PDF asset URLs in user/org context and lazy-load preview rendering only when requested. |

| Testing checklist | Verify Manager quotation list only includes self/team; verify other-team quotation by ID returns 403; verify approval/rejection rules; verify rejection reason required; verify PDF preview with logo/QR/signature; verify status filters/export; verify mobile layout. |

7. Customers

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Customer view appears based on won prospects and inherits Manager prospect scoping. Risk: dashboard customer conversion metric may not match Customers page if one uses team-assigned-by-manager scope and the other uses Manager/team prospect visibility. Customer conversion from won quotations/prospects should be clarified: approval of a quotation does not necessarily guarantee linked prospect/customer state is updated. |

| Edge cases to test | Prospect marked WON by Manager; quotation approved for team Executive; customer created from Manager direct lead; customer created from team lead assigned by Admin; lost/won terminal updates; duplicate customer-like prospect records. |

| Severity | Medium |

| Affected functionality | Customer totals, conversion rate, reports, dashboard alignment. |

| Possible root cause | Customer is derived from prospect/quotation states rather than a single customer entity lifecycle. KPI scopes are not fully unified. |

| Best-practice solution | Define one conversion source of truth. If a won quotation creates a customer, update prospect/customer state transactionally. Dashboard, Customers, and Reports should use the same Manager-owned customer scope. |

| Performance improvements | Index `Prospect(organizationId, stage, assignedToId)` and precompute customer conversion totals for dashboard/report periods. |

| Testing checklist | Verify Customers page shows Manager direct and team won customers only; verify other-team customer is blocked; verify dashboard customer total equals filtered Customers count for same range; verify search/filter/pagination; verify empty and mobile states. |

8. Reports

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Report backend applies Manager filters for leads, prospects, quotations, and activities using self plus direct reports. The Executive filter is not explicitly validated, and the frontend filter options come from the lead assignable-users endpoint, currently exposing all org Executives. Report endpoints compute all report tabs for each tab request, which is expensive. Pagination `limit` is not capped in repository code. CSV export pulls up to 10,000 records without an audit event. |

| Edge cases to test | Manager filters by other-team Executive ID; Manager exports lead/prospect/quotation reports; large date range; source filter on non-lead tabs; empty date range; invalid custom date range; disabled Executive historical records. |

| Severity | High |

| Affected functionality | Data isolation through filters, report accuracy, export governance, performance. |

| Possible root cause | Frontend reuses lead assignment endpoint for report filters. Repository APIs use one combined reports response and unbounded query limits. Export is treated as normal read. |

| Best-practice solution | Validate `executiveId` against Manager's direct team and return 403 for unauthorized IDs. Provide tab-specific endpoints or compute only requested report. Cap limits, audit exports, and include filter metadata in audit logs. |

| Performance improvements | Add composite indexes for report date/status/owner fields. Replace in-memory grouping for source/performance with database aggregations where practical. Add CSV streaming for large exports. |

| Testing checklist | Verify reports show only Manager self/team data; verify filter dropdown only direct team; verify unauthorized executive filter returns 403; verify charts match tabular totals; verify CSV scope; verify mobile report tabs; verify dark/light chart colors. |

9. Profile

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Manager can edit personal profile fields and upload quotation assets in UI. UI hides password change for Manager, but backend `/auth/change-password` is open to any authenticated user. Backend profile update accepts organization assets from any authenticated org user if files are submitted; UI allows Admin/Manager, but backend does not enforce that role boundary. |

| Edge cases to test | Manager changes first/last/mobile; Manager hits change-password URL directly; Manager uploads logo/QR/signature; Executive uploads org assets via crafted request; oversized or invalid file type; stale asset in PDF preview. |

| Severity | High if password/assets are restricted by policy; Medium otherwise |

| Affected functionality | Profile security, organization PDF assets, quotation branding, session invalidation. |

| Possible root cause | UI role rules are not mirrored in backend. File upload middleware runs before policy-level checks. |

| Best-practice solution | Move profile field policy to backend. Explicitly define Manager allowed fields. If Managers cannot change passwords, block in service/controller. If only Admin/Manager can upload assets, enforce role and organization status server-side before accepting files. |

| Performance improvements | Compress/resize images on upload; store asset dimensions/type; use cache headers for uploaded assets. |

| Testing checklist | Verify allowed profile fields persist; verify restricted fields are rejected by API; verify Manager password route behavior matches product rule; verify uploaded assets appear in PDF preview; verify invalid files are rejected; verify dark/light profile view. |

10. Settings

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Settings is included in the requested Manager audit modules, but current route and sidebar configuration restrict Settings to Super Admin and Admin. This is safe if Managers should not access organization/billing settings. It is a product gap if Managers need personal/team settings. |

| Edge cases to test | Manager visits `/settings`; Manager receives notification pointing to settings; Manager attempts billing/usage endpoint; organization suspended; feature disabled by subscription. |

| Severity | Medium |

| Affected functionality | Settings access, notification navigation, user expectation. |

| Possible root cause | Product scope and route matrix are not aligned in documentation/request. |

| Best-practice solution | Decide the intended Manager Settings surface. If needed, create a separate Manager settings page for preferences only, with no billing/org-admin controls. If not needed, remove Manager Settings from role documentation and help copy. |

| Performance improvements | Lazy-load settings tabs by role. Avoid fetching billing/org config for roles that cannot access it. |

| Testing checklist | Verify Manager cannot access Admin/Super Admin settings; verify 403 page is clear; verify notification links avoid settings for Manager; verify Help does not instruct Manager to use unavailable settings. |

11. Help

| Category | Audit Detail |

| --- | --- |

| Bugs/issues found | Manager help is minimal. It says Managers can see Executives within their organization, but the actual business rule should be direct-report Executives only. The lead assignment FAQ does not mention direct team restrictions. General help is static and does not guide Manager-specific quotation approval, follow-up, reports, or restricted settings/password behavior. |

| Edge cases to test | Manager searches "settings", "password", "quotation approval", "assign executive", "reports export"; no search results; mobile help layout; dark/light FAQ cards. |

Severity	Low
Affected functionality	Self-service support, onboarding, reduced support load.
Possible root cause	Help content is not tied to current role-permission matrix.
Best-practice solution	Update Help after policy decisions. Add role-specific FAQs for Manager team scope, assignment, quotation approval limitations, follow-up ownership, report filters, and profile restrictions.
Performance improvements	Keep static FAQs lightweight; if content grows, index client-side or fetch per role.
Testing checklist	Verify Manager FAQs match actual permissions; verify search returns role-relevant content; verify Help links only to accessible pages; verify responsive and dark/light styling.

Cross-Cutting Backend/API Findings

Severity	Finding	Suggested Fix
Critical	Manager authorization is inconsistent between list endpoints and direct-ID mutation endpoints. Centralize `buildManagerScope(user)` and `assertManagerScope(user, target)` utilities. Use them in every service, not just repositories.	
Critical	Assignment validation for leads/prospects allows any org Executive. Make assignment validators role- and relationship-aware. Add unit tests for Manager A vs Manager B teams.	
High	Some UI gates are stronger than backend gates, especially profile password/assets. Treat frontend gates as convenience only; enforce every policy in backend.	
High	Report/export governance is thin. Audit every export with user, role, org, filters, row count, and export type. Cap limits and stream large exports.	
Medium	API pagination limits are not consistently capped. Add schema-level max limits and repository safeguards.	
Medium	Suspended organization handling is strongest at login; long-lived sessions should also be checked on privileged mutations. Add organization status checks in auth middleware or a tenant-access middleware.	
Medium	Empty/loading/error states exist, but action visibility often uses role shortcuts rather than permission helpers. Use one frontend permission module generated from or aligned with backend role permissions.	

Database / Prisma Audit Notes

- Add or verify composite indexes for Manager-scoped queries:
 - `User(organizationId, role, managerId, status, deletedAt)`
 - `Lead(organizationId, assignedToId, deletedAt, status)`
 - `Lead(organizationId, assignedById, assignedToId)`
 - `Lead(organizationId, productInterestId)`
 - `Prospect(organizationId, assignedToId, stage, followUpDate)`
 - `Quotation(organizationId, assignedToId, createdById, status, date, deletedAt)`
 - `Notification(userId, readAt, createdAt)`
- Avoid relying on nested relation filters without matching indexes on foreign keys.
- Validate all cross-entity connects with organization scope before Prisma connect.
- Use transactions for flows that change multiple lifecycle states, such as quotation approval leading to prospect/customer conversion.

Security Audit Notes

- Enforce Manager team authorization server-side for every ID-based route.
- Avoid returning empty results for unauthorized filters when the same endpoint reveals that a user ID exists. Prefer 403 for explicit unauthorized IDs.
- Do not expose all org Executive names through shared assignment/filter endpoints.
- Keep UI action hiding, but never depend on it as an authorization boundary.
- Audit Manager exports and sensitive mutations.
- Rate-limit login/refresh already exists; consider rate limits on exports/imports and file uploads.
- Ensure uploaded profile/org assets are validated by type, size, and role before persistence.

Improvement Roadmap

Phase 1: Critical Access Control Fixes

1. Implement shared Manager scope utilities:
 - `isManagerSelfOrDirectReport(managerId, userId)`
 - `assertManagerCanManageUser(manager, targetUser)`
 - `buildManagerOwnedResourceWhere(managerId)`
2. Apply direct-report checks to user detail/update/disable/enable/delete.
3. Fix lead/prospect assignee validation to allow Manager self or direct-report Executives only.
4. Fix `getAssignableUsers` so Manager sees only self plus direct reports.
5. Validate lead `productInterestId` by organization before create/update/import connect.

Phase 2: Workflow And UI Permission Alignment

1. Hide Manager delete actions for Leads and Quotations unless backend permission is intentionally added.
2. Add quotation status UI rules for Manager:
 - Manager can approve/reject direct-report Executive quotations.
 - Manager cannot approve/reject own quotations.
 - Rejection requires reason.
3. Align profile password and asset upload rules between frontend and backend.
4. Confirm whether Manager Settings should exist; build a restricted page or document that it is not available.
5. Confirm whether Manager can manage Items; current system exposes Items to Managers though the requested Manager module list does not include it.

Phase 3: Reporting, Audit, And Data Accuracy

1. Validate report `executiveId` filters against direct team.
2. Audit CSV exports with filter metadata and row counts.
3. Split report endpoints by tab or add `reportType` so inactive tabs are not computed.
4. Align dashboard/customer/report conversion definitions.
5. Move user stats and heavy dashboard/report metrics to backend aggregates.

Phase 4: UX, Responsiveness, And Dark/Light Polish

1. Run mobile viewport checks for tables, action menus, dialogs, and charts.
2. Test dark/light chart contrast and status badge contrast.
3. Improve Help content for Manager-specific workflows.
4. Add clearer empty states for no team, no leads, no prospects, no quotations, and no report results.
5. Add actionable API error messages for unauthorized team actions.

Phase 5: Performance Hardening

1. Add missing indexes based on query plan review.
2. Cap all list/report/export limits.
3. Convert high-volume report in-memory grouping to DB aggregation.
4. Stream CSV exports.
5. Cache dashboard summaries for high-volume tenants with short TTL invalidation on relevant mutations.

Module-Wise Testing Checklist

Dashboard

- [] Manager with no Executives sees zero-state dashboard without crashes.
- [] Leads Assigned includes only leads directly assigned to Manager.
- [] Leads Assigned to Team includes only leads assigned by Manager to direct-report Executives.
- [] Open Leads includes only `NEW`, `ATTEMPTED\_CONTACT`, and `CONTACTED`.
- [] Executive performance chart shows only active direct-report Executives.
- [] Dashboard excludes other Managers, Admin, Super Admin, and other organizations.
- [] Customer conversion KPI matches defined Manager/customer scope.
- [] Follow-up due/overdue metrics handle timezone boundaries.
- [] Mobile dashboard widgets do not overflow.
- [] Dark/light chart colors remain readable.

Notifications

- [] Manager sees personal notifications only.
- [] Manager sees org/role-targeted announcements intended for Managers.
- [] Manager does not see Admin-only or Super Admin-only announcements.
- [] Notification link to reassigned/deleted record handles 403/404 gracefully.
- [] Mark-all-read clears more than 200 unread notifications or paginates clearly.
- [] Notification settings links do not point Managers to inaccessible Settings.
- [] Mobile notification feed is usable.
- [] Dark/light notification cards and badges are readable.

Users / Executives

- [] Manager list shows only direct-report Executives.
- [] Manager cannot view another Manager's Executive by direct ID.

- [] Manager cannot update another Manager's Executive by direct ID.
- [] Manager cannot disable/enable/delete another Manager's Executive.
- [] Manager cannot change an Executive's manager to someone else.
- [] Manager-created Executive is automatically assigned to that Manager.
- [] Seat limit is enforced on create and enable.
- [] User stats are correct across all pages.
- [] Audit log records Manager user create/update/disable/enable/delete.
- [] Forms are responsive and dark/light consistent.

Leads

- [] Manager lead list includes own and direct-team leads only.
- [] Manager cannot access other-team lead by ID.
- [] Assign dropdown shows only Manager plus direct-report Executives.
- [] API rejects assignment to another Manager's Executive.
- [] Lead create/update rejects cross-org item/productInterestId.
- [] Converted lead cannot be edited/status-changed by Manager if restricted.
- [] Manager delete action is hidden or backend permission intentionally exists.
- [] Search/filter/pagination preserve Manager scope.
- [] Empty/loading/error states are clear.
- [] Dark/light table and mobile cards are readable.

Prospects

- [] Manager sees own/direct-team prospects only.
- [] Manager cannot access other-team prospect by ID.
- [] Prospect assignment and follow-up assignment allow only self/direct team.
- [] Qualified lead conversion creates correctly scoped prospect.
- [] Terminal `WON/LOST` prospects are read-only for Manager if intended.
- [] Follow-up overdue logic is correct for today/timezone.
- [] Search/filter/pagination preserve Manager scope.
- [] Activity log records follow-up and stage changes.
- [] Empty and loading states are clear.
- [] Mobile and dark/light UI are consistent.

Quotations

- [] Manager sees own/direct-team quotations only.
- [] Manager cannot access other-team quotation by ID.
- [] Manager can assign quotation only to self/direct reports.
- [] Manager cannot approve/reject own quotation.
- [] Manager can approve/reject direct-report Executive quotation.
- [] Reject flow requires reason in UI and API.
- [] Approved/rejected status transitions follow allowed matrix.
- [] Delete action is hidden for Manager unless backend permission is added.
- [] PDF preview renders logo, QR, signature, totals, and pagination correctly.
- [] Mobile quotation cards and dialogs are usable in dark/light mode.

Customers

- [] Customers page shows only Manager/direct-team won customers.
- [] Other-team customer/prospect is inaccessible.
- [] Dashboard customer KPI matches Customers page for same scope.
- [] Won quotation/customer conversion rule is consistent.
- [] Search/filter/pagination preserve Manager scope.
- [] Empty state is clear when no customers exist.
- [] Mobile customer cards do not overflow.
- [] Dark/light status and table styling are readable.

Reports

- [] Manager report totals include only own/direct-team data.
- [] Executive filter dropdown shows only direct-report Executives.
- [] API rejects unauthorized `executiveId`.
- [] Lead, prospect, quotation, and performance charts match tabular totals.
- [] CSV export preserves Manager scope.
- [] Export audit record includes user, role, org, filters, row count, and type.

- [] Large date ranges remain performant.
- [] Empty reports render useful empty states.
- [] Mobile tabs/charts/tables are usable.
- [] Dark/light chart colors meet contrast needs.

Profile

- [] Manager can update allowed personal fields.
- [] Restricted profile fields are blocked by API.
- [] Manager password change behavior matches product rule.
- [] Organization asset upload is role-gated server-side.
- [] Invalid/oversized files are rejected before persistence.
- [] Uploaded assets appear in quotation PDF preview.
- [] Profile page handles failed upload gracefully.
- [] Mobile profile form is usable.
- [] Dark/light upload previews are readable.

Settings

- [] Manager cannot open Admin/Super Admin settings.
- [] If Manager settings are required, Manager sees only restricted personal/team preferences.
- [] Settings route does not fetch billing/org-admin data for Manager.
- [] Notification/help links do not send Manager to unavailable settings.
- [] 403 page is clear and non-confusing.
- [] Mobile and dark/light access-denied views are polished.

Help

- [] Manager FAQs mention direct-report team scope.
- [] Help explains lead assignment restrictions.
- [] Help explains quotation approval restrictions.
- [] Help explains report filters and exports.
- [] Help does not mention unavailable Settings/password actions unless policy allows them.
- [] Search returns useful Manager-specific results.
- [] No-results state is clear.
- [] Mobile and dark/light Help views are readable.

Recommended Acceptance Criteria Before Manager Audit Closure

- A Manager cannot view, mutate, assign, export, or filter data outside self/direct-report scope by UI or direct API.
- Manager lead/prospect/quotation assignment dropdowns and APIs return the same allowed user set.
- Manager user management APIs reject other-team Executive IDs with 403.
- Dashboard, Customers, and Reports use the same documented Manager conversion/customer definitions.
- Manager UI actions are permission-aware and do not show operations backend will always reject.
- Profile/password/asset rules are enforced server-side.
- Reports exports are scoped, capped/streamed, and audited.
- Empty, loading, error, mobile, and dark/light states pass module-level checks.